Grounding and Bias-Risk Controls for a College Interview Bot with Zero Trust Access

Sai Pranavi A P Sai Triveni B
Sanjana H V Sneha V
Department of Artificial Intelligence and Machine Learning
RV College of Engineering, Bengaluru, India

***Abstract*—College interview bots must protect student assessments while preventing unsupported feedback and unequal review burden. We present TrustInterview AI as a controlled reference workflow with separate decisions for server-side resource access and evidence-quotation release. The access decision checks provisioned identity, role, scope, ownership and session validity. The output decision checks quotation provenance, a bounded source-relative claim grammar and selected bias-risk signals. Draft subject-reference quotations require review; automatic practice/continue judgments are withheld because the current keyword score is not a validated rubric. Ninety-one backend and six interface tests pass. Negative access cases demonstrate denials for foreign ownership, expired sessions and replay, while a copied valid bearer token retains owner access until revocation. Nine authored output-policy probes show that a literal but technically false statement and an indirect culture-fit judgment pass the current checks. Earlier artifacts contain twelve analysis-tool tests and a forty-eight-record synthetic offline pilot. These are conformance and recording results, with no live model calls or independently labelled efficacy data. General technical correctness and demographic fairness remain unmeasured.**

***Index Terms*—college interview bot, zero trust, hallucination risk, bias risk, source grounding, output assurance**

I. Introduction

A college interview bot may ask a technical question, receive a student's answer and return feedback for practice or authorized assessment review. Its output can incorrectly attribute a statement to the student, repeat a technical error as if it were correct, or treat otherwise comparable answers differently. A valid login does not make generated feedback reliable, and a warning has little value if the warned artifact is still released. The research problem is therefore to control both access to an assessment and release of its output.

The project also includes historical campus-placement and resume features. This paper reports a narrower controlled candidate/reviewer workflow with one fixed Zero Trust Architecture (ZTA) question and a keyword score used to test authority boundaries. It presents a systems architecture and its preliminary verification. The prototype does not establish academic grading validity or make an employer selection decision.

NIST SP 800-207 grounds the resource-access decision in a policy engine and enforcement point [1]. We couple this with an application-level output decision that treats model responses as untrusted proposed artifacts. The contribution is the explicit interaction: source and risk checks can withhold output after an otherwise authorized request, while a model cannot grant itself resource access. This does not make semantic correctness or fairness an inherent property of ZTA.

We distinguish three feedback errors. Student attribution requires evidence from the student's answer. A technical explanation requires a reviewed subject source and semantic assessment. A judgment of mastery requires a declared rubric and answer evidence. A resume statement supplies only candidate-origin evidence; it neither proves a qualification nor establishes domain truth. Our implemented checks cover exact quotation provenance, a narrow technology-use grammar and selected review signals. General technical entailment and fair scoring remain evaluation goals. We contribute a coupled release design, a versioned controlled prototype and a reproducible verification and evaluation protocol.

II. Related Work

NIST SP 800-207 describes policy decision and enforcement for protected resources [1]; SP 800-207A discusses cloud-native access control [2]. NIST SP 1800-35 documents example ZTA implementations rather than a fixed layer count [3]. The NIST Generative AI Profile separately treats confabulation and harmful bias as risks needing evaluation [4]. None of these sources defines a 13-layer ZTA standard or implies that authorization verifies a model's statement.

FActScore motivates claim-level factual support rather than treating a whole answer as one correct or incorrect unit [5]. AlignScore shows why semantic consistency requires methods beyond matching a quotation to source text [6]; we do not claim either method is implemented here. Educational grading research has examined instructor-provided answers and rubrics [7]; the Short Answer Feedback dataset pairs learner responses with reference answers and explanatory feedback [8]. These works reinforce the need for a meaningful assessment construct before presenting a bot judgment as a grade. SelfCheckGPT estimates unreliable generation from sample consistency [9], which also differs from evidence support.

Fairness in a student-facing bot concerns comparable feedback and review decisions for comparable technical answers. Educational essay-scoring research has examined demographic differences in automated scores [10], while educational-explanation research has examined demographic variation in generated content [11]; neither result can be transferred

directly to technical interviews. Studies of language-model hiring decisions and name effects supply adjacent counterfactual methods [12], [13]; their employment outcomes likewise cannot be imported as college interview results. Research on language varieties shows that style can affect model responses [14]. FairPair motivates matched perturbations with attention to generation variability [15]. For technical interviews, style variants need faculty validation that meaning is preserved; communication quality can be a legitimate criterion only when it is explicitly assessed. A sensitive-word screen by itself cannot establish equal treatment.

Untrusted student material can also carry instructions. Resume-screening attacks and OWASP guidance motivate treating source text as data, not policy [16], [17]. Our architectural position is the coupling of resource authorization, source-constrained output and review state; its practical benefit over simpler controls still requires matched experiments.

III. Terminology and Threat Model

A. Actors, Assets and Assumptions

The protected assets are student answers, optional resume and subject-reference text, assessment state, test scores, proposed quotations and review records. Students access their own assessments within an assigned scope; authorized reviewers inspect held assessments within that scope. The browser, candidate material and model responses are untrusted inputs. The backend policy implementation, provisioned principal registry and authoritative store form the trusted computing base. Compromise of these components is outside the prototype's demonstrated protection.

Our reference deployment is a single backend instance with exclusive ownership of its SQLite database. Sessions are volatile and require new authentication after restart. Identity can be provisioned locally or mapped from a verified external subject, but real Google sign-in has not been exercised. Tenant and role bindings remain server-owned. No biometric identity, proctoring or identity inference from names is included.

B. Output Definitions

Source-supported means the available evidence supports a statement within the declared comparison scope. Source-contradicted requires explicit incompatible evidence in the same scope. Undetermined covers missing, insufficient, ambiguous or conflicting evidence. Absence of a technology in a resume is not contradiction, and a supported resume quotation is not external qualification verification. Model-origin unsupported assertions and candidate-origin source inconsistencies are recorded separately.

Bias-risk evidence is a signal for inspection, not a discrimination finding or an estimate of unequal treatment. In the prototype, selected sensitive-attribute terms and instruction-like phrases are deterministic review triggers. Their vocabulary and contextual limits are explicit. Operational abstention is also separate from the semantic label undetermined: a provider failure can cause abstention without producing a claim label.

TABLE I
PROJECT-SPECIFIC LAYER MAP AND EVIDENCE BOUNDARY

Legacy labels	Controlled-workflow interpretation
L1 identity, L9 policy	Server-side session, role, scope and ownership decisions are exercised.
L2 device, L3 network, L10 edge	Legacy protections; not established by controlled-service tests.
L4 workload, L5 data, L8 governance	Bounded schemas and evidence hashes are exercised; legacy PDF and edge paths are separate.
L6 audit, L7 automation, L11 threat intelligence	Transactional audit and recovery are exercised; legacy IP response is outside this result.
L12 bias, L13 grounding	Selected review signals, exact quotations and bounded claim comparison are exercised; efficacy is unmeasured.

Table I summarizes the thirteen project-specific legacy labels; they are not a NIST-prescribed layer model, and the default controlled service does not mount every legacy middleware path. As with bearer tokens generally [18], an attacker with a copied valid session token can act as its owner until expiry or revocation; this prototype does not demonstrate device binding or resistance to a compromised browser. Likewise, database hashes provide local consistency checks, not protection against an administrator rewriting the store and its audit history. These limits define which threat claims the tests can support.

IV. Dual Policy Zero Trust Architecture

A. Decision Separation

Figure 1 shows the two assurance planes. The access plane decides whether a principal may act on a resource. The output plane decides whether the resulting artifact may be released. The latter is an application policy extension, not a claim that NIST defines fairness as an access-control property. We express the decisions as

$$D_A = f_A(I, R, T, O, S, X), \tag{1}$$

$$D_O = f_O(A, E, B, G, P, H), \tag{2}$$

where I is identity, R role, T tenant, O ownership, S session status and X assessment context. For output, A is the proposed artifact, E its bound evidence, B bias-risk signals, G grounding results, P provenance and H control availability. A release transition requires valid access and an acceptable output decision. Neither a successful provider call nor a detector score grants resource authority.

For the implemented output policy, let U mean an invalid contract, unknown or fabricated quotation, or an extracted claim with undetermined support. Let V mean a source contradiction, draft-reference quotation or selected review signal. With validity checked before risk routing, the result is

$$\begin{aligned} D_O &= \text{abstain} \quad \text{if } U = 1; \\ D_O &= \text{review} \quad \text{if } U = 0, V = 1; \\ D_O &= \text{allow} \quad \text{if } U = 0, V = 0. \end{aligned} \tag{3}$$

Here "allow" denotes passage through these implemented checks, not factual truth or fairness. Provider and commit failures withhold release independently of this artifact rule.

The architectural access outcomes include allow, deny, step-up and revoke. The current reference service implements allow/deny with expiry and revocation; interactive step-up is not implemented. The output design admits release, regeneration, abstention, review and denial. The implemented path releases valid output, holds selected findings for review, or abstains; regeneration is not implemented. Stating these differences avoids presenting every conceptual policy outcome as an existing feature.

B. Resource and Session Enforcement

The backend resolves a principal from a provisioned credential or trusted identity adapter. It issues an opaque session token and keeps expiry and revocation state on the server. Protected routes require that token. For candidates, every assessment operation checks role, tenant and owner; reviewers may inspect only held resources in their tenant. Inaccessible resources return a non-disclosing resource error. A role string or user identifier submitted in JSON cannot replace these bindings.

Assessments are created with a server-owned question and rubric. Submission accepts an answer rather than a client score, and begins a versioned transition from awaiting-answer to evaluating. Concurrent or repeated submissions cannot overwrite committed state. After asynchronous provider work, session validity is checked again before release. A revoked or expired session cannot gain a scored result simply because the provider completed successfully.

The external identity adapter uses browser-bound state, nonce, Proof Key for Code Exchange (PKCE) and a server-assigned subject mapping following Google OpenID Connect documentation [19]. Signed local test assertions exercise cryptographic validation and negative claims; code exchange and key retrieval are fixtures. This establishes selected protocol behaviour, not successful live authentication. Reviewer access still derives from the server's binding rather than provider-supplied role text.

C. Source Binding and Grounding

An optional plain-text resume is attached once before submission. The input is bounded to 8000 UTF-8 bytes, rejects unexpected authority fields and invalid text, and belongs to the candidate's assessment. The store records its text and SHA-256 digest with a correlated audit event. The digest is checked before provider invocation and enters the cache context. Evidence is copied for the provider, preventing its in-process mutation from becoming authoritative source state. PDF ingestion and OCR are not implemented in this controlled path.

The feedback contract permits bounded exact quotations linked to answer, question, resume or an optional versioned subject reference. Unknown source identifiers, fabricated quotations and unexpected output fields cause abstention. This is structural provenance checking: a quoted falsehood can pass, a relevant phrase can omit context, and correct paraphrases cannot pass a quotation-only contract. A research-draft reference quotation is held for review; an unknown or fabricated quotation causes abstention. Even a faculty-reviewed status is an administrative record, not proof that the quoted content is correct. Accordingly, quotation matching is not reported as general semantic hallucination detection.

The current claim checker adds a deliberately limited resume-relative source comparison to both the answer and valid quoted observations. It recognizes whole-line first-person technology-use statements and their explicit negations, using a fixed alias vocabulary. Same-polarity evidence is source-supported; opposite-polarity evidence is source-contradicted. Missing assertions, conflicting statements, unknown technologies and unsupported wording remain undetermined. Java and JavaScript are distinct, while aliases such as JS and JavaScript are explicitly mapped. General prose, dates, duration and competence require a broader semantic method. When no claim is extracted, the input is outside the checker's recognized scope; it is not verified.

TABLE II
IMPLEMENTED OUTPUT-POLICY PRECEDENCE

Condition	Action
Malformed output, unavailable source or fabricated quote	Abstain
Extracted claim has undetermined support	Abstain
Source contradiction, draft subject reference or selected risk trigger	Hold for review
No blocking condition in the implemented scope	Release quotes and fixture score
Provider, session or durable-commit failure	Withhold result

D. Bias-Risk Routing and Release

The output screen records exact matches and quote-relative offsets for selected sensitive-attribute and instruction-like phrases. A bounded technical exception handles *race condition* when no other race reference occurs in the bound source. A finding routes the output to review rather than asserting discrimination. This prevents certain flagged artifacts from being silently released but may impose review on benign disclosures and may miss indirect or stylistic effects. These are fairness risks to measure, not verified mitigations. Source provenance is retained so that a candidate disclosure is not automatically treated as a model's demographic judgment.

Table II defines precedence: review cannot override an abstained grounding failure. A same-tenant reviewer can approve or reject a held result only by recording a reason. Approval authorizes release of its quotations; it does not verify technical correctness, student mastery or the scoring rubric. Rejection withholds the score. Candidate displays contain scores and feedback only after durable release, including when a malicious response contains a score field in a held state.

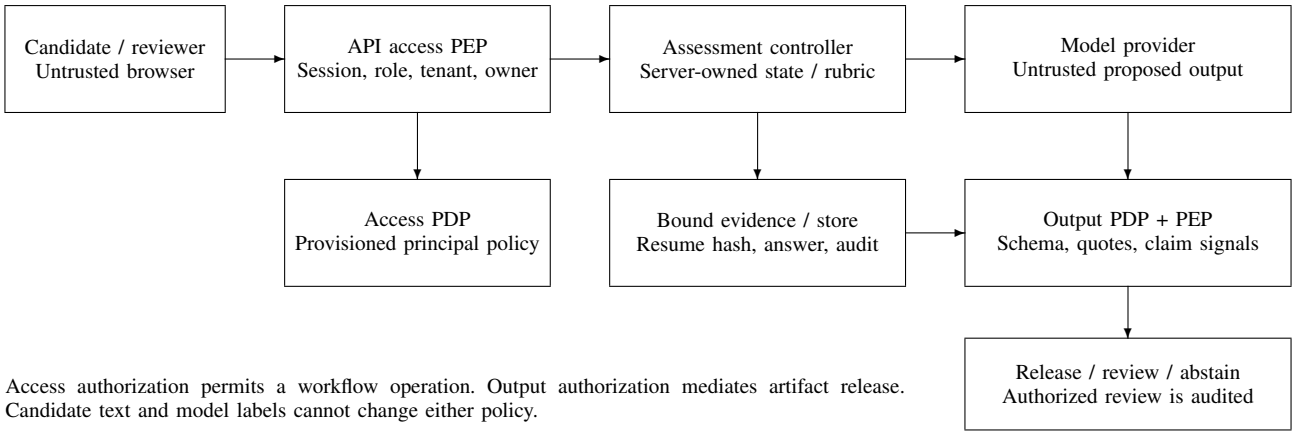


Fig. 1. Coupled assurance planes. Solid arrows show processing or evidence dependencies; all protected reads and mutations remain mediated by the access PEP.

E. Persistence, Audit and Failure Handling

Assessment mutation and its audit event commit in one SQLite transaction. Compare-and-swap version checks prevent stale updates. A crash during provider evaluation leaves durable evaluating state; startup recovery changes interrupted assessments to abstained and removes uncommitted result fields. Exclusive database ownership prevents a second instance from recovering another active instance's work. The design is a single-instance reference implementation, not a distributed availability claim.

Audit records contain policy version, correlated request, action and decision, hashed principal references and selected source/review hashes. A hash chain detects some local alterations but lacks external anchoring and cannot prevent privileged rewriting or valid-prefix truncation. Resume and answer evidence remain plaintext in the database. Sessions and caches are volatile. Cache writes follow durable release and use candidate/session/assessment/source context; cache reuse and eviction have not been evaluated.

V. Prototype Implementation and Boundaries

A. Historical Prototype and Controlled Reference

The historical INTERVIEW-BOT and TrustInterview-AI repositories supply implementation context, not the final research evidence. A code review identified anonymous session issuance, inconsistent ownership checks, client-authoritative scores, shared question context, route-dependent detector behaviour and simulated interface values. Missing resume evidence could also be interpreted as verified by a heuristic path. These observations motivated an isolated reference boundary rather than a claim that the original middleware already established ZTA.

The controlled backend is the default entry point and serves a dedicated candidate/reviewer interface. Historical routes remain available only through an explicit legacy entry point and are not mounted by the controlled service. Table III summarizes what has been implemented and what remains limited. Backend and analysis sources, test reports and versioned input files are retained with SHA-256 manifests. The long traceability review and test logs are supporting artifacts; their detail is not counted as a separate research contribution for each remediation step.

TABLE III
Reference implementation and evidence boundaries

Component	Implemented boundary / remaining limitation
Identity and access	Provisioned subjects, scoped resources, expiry and revocation; live external sign-in untested.
Evidence sources	Owned resume text and optional versioned subject reference; no semantic truth guarantee.
Output assurance	Exact quotations, bounded claim grammar, draft-source holds and review triggers; no validated general detector.
Persistence and review	Transactional state, recovery and reasoned reviewer decisions; single-instance plaintext store.
Scoring	Server-owned three-term keyword fixture; no student competence validity.
Model integration	Optional bounded Gemini adapter; transport fixtures only, no live interoperability result.

The fixture score is the rounded percentage of the terms *identity*, *authorization* and *resource* occurring as words in the answer. Term presence, rather than repetition or resume content, determines this value. This transparent rule permits reproducible authority tests but supplies no evidence of competence.

B. Model Adapter and Recording Protocol

The optional Gemini REST adapter uses a fixed service endpoint and privately configured credentials. It transmits bounded evidence, requests a constrained JSON schema and invokes no tools. Timeouts abort requests; HTTP errors, blocked or incomplete responses, malformed JSON and oversized bodies fail closed. Live mode has no automatic offline fallback. The default provider remains an explicitly labelled offline fixture.

TABLE IV
CURRENT VERIFICATION ARTIFACT

Check	Recorded outcome
Backend controls, identity, persistence, grounding, provider and runner	91 tests passed
Candidate/reviewer and mode-disclosure interface	6 tests passed; build succeeded
Annotation schema and metric arithmetic	12 artificial tests passed
Earlier synthetic offline recording pilot	48 records; 0 live calls
Independent annotations and live efficacy	Not collected

The format follows the provider documentation [20]; fixture tests do not establish live API interoperability or reliability.

A sequential experiment runner uses a bounded seeded plan and a fresh output directory. It records input and prompt-template hashes, provider/model and decoding metadata, request identifiers, response references, token usage when supplied, duration and decisions. Successful bounded responses retain their envelopes; failed or rejected requests retain sanitized diagnostics. Partial runs remain marked incomplete. This filesystem recorder is not the transactional assessment store and does not promise power-loss durability.

Grounding predictions and paired-output records are exported separately in the earlier protocol pilot. A live semantic label would remain an untrusted prediction even when its cited quotation exists. The earlier paired workflow kept the fixed ZTA question and keyword score; its job-text perturbations do not alter that rubric. Its appropriate outcomes are feedback-source selection and release, abstention or review burden. It cannot measure model-driven student grading fairness. College-specific answer and presentation pairs are required for that question.

VI. VERIFICATION AND EVALUATION PROTOCOL

A. Current Verification Results

The retained verification environment uses Node.js v22.20.0 on Windows x64 for the controlled backend and a separate Python analysis utility. Table IV distinguishes the latest controlled checks from earlier protocol artifacts. Test inputs were authored to exercise selected policy and schema conditions; they were not sampled from a threat population or independently labelled applicant corpus. Passing counts therefore establish conformance for those inputs, not accuracy estimates.

To expose the rule's boundary, we ran nine authored inputs directly against policy version research-0.8; Table V reports the observed decisions. The probe script, case text and JSON record are retained with the project. These cases were deliberately selected to exercise both expected enforcement and known blind spots. They are neither a random sample nor independent gold labels, and their count is not an accuracy denominator.

P2 demonstrates that exact source quotation preserves a student's false statement without assessing domain truth. P4 establishes only the reference's recorded review status. P7 shows a possible false review burden for a student disclosure, while P9 shows that an indirect judgment can evade the lexical screen. The rule in (3) predicts these results; the probes do not validate a general hallucination or discrimination detector.

TABLE V
AUTHORED CURRENT-POLICY PROBES; NOT EFFICACY ESTIMATES

ID	Probe condition	Decision
P1	Fabricated student quotation	Abstain
P2	Literal but technically false answer	Allow
P3	Draft subject-reference quotation	Review
P4	Faculty-reviewed reference quotation	Allow
P5	Explicit answer–resume contradiction	Review
P6	Explicit claim absent from resume	Abstain
P7	Literal disability disclosure	Review
P8	Technical "race condition" phrase	Allow
P9	Indirect culture-fit judgment	Allow

TABLE VI
ZERO TRUST NEGATIVE CASES IN THE CONTROLLED SERVICE

ID	Adversarial condition	Observed result
Z1	Unknown credential / unprovisioned subject	Deny
Z2	Expired or revoked session	Deny
Z3	Foreign owner, tenant or reviewer	Deny
Z4	Client role or score substitution	Deny input
Z5	Replayed or racing submission	Deny update
Z6	Revocation during provider work	Abstain
Z7	Audit fault or interrupted evaluation	No scored release
Z8	Copied live owner bearer token	Owner read allowed

Access tests exercise unprovisioned identities, isolation by role, tenant and owner, expiry, revocation, replay, concurrent submission and client-score rejection. Output tests exercise unsupported quotations, extra model fields, review authorization and withheld scores. Persistence tests check atomic commits of state and audit events, stale versions, exclusive ownership and abrupt process exit during a transaction. Reopening the crash fixture rolls back a fake uncommitted release and records abstention for interrupted evaluation. Identity tests verify locally signed RSA assertions with the installed SDK and reject altered signatures and invalid issuer, audience, nonce and expiry claims. They do not use a live Google account.

Table VI makes negative access and state cases explicit. Z1–Z7 are denial or withholding behaviours observed under authored fixtures; they are not an attack-prevention rate. Z8 is a demonstrated residual failure of token theft resistance: the service has bearer sessions without device binding, so a copied live owner token is accepted as the owner until revocation. Authorization is enforced for the presented credential, but the system cannot distinguish its holder. The separate output policy still cannot infer technical truth from a quotation.

Provider tests use injected transport fixtures to check request boundaries, secret handling, timeout abort and failure outcomes. The earlier forty-eight-case runner smoke check retains twenty-four grounding and twenty-four paired records. Raw hashes, complete case coverage and cross-language input

hashes validate against the annotation importer. These earlier records are offline protocol artifacts, not outputs of the latest policy version; no prediction-to-gold analysis is performed because human labels remain blank. The keyword score ignores demographic text and source discrepancies; equal scores under this fixture are expected by construction and are not a fairness result.

B. Research Questions and Study Configurations

The proposed efficacy study asks four questions. RQ1 asks whether resource and transition controls prevent unauthorized reads and scored releases under adversarial requests. RQ2 asks how accurately the grounding method distinguishes supported, contradicted and undetermined claims, including extraction failures. RQ3 asks whether output decisions and error burdens change across meaning-preserving student-answer and identity/presentation pairs. RQ4 asks what latency, failure and review cost the coupled controls introduce under a specified workload.

The proposed configurations isolate contributions: C0 is a declared baseline, C1 adds access assurance, C2 adds output assurance, C3 combines both, and C4 adds the selected advanced semantic method. They must share the same provider, rubric, input set and decoding settings when the comparison requires them. The earlier component timings are not evidence that these live system ablations have been run. Any control disabled for a synthetic experiment remains separate from a deployed protected workflow.

C. Prepared Corpora and Independent Annotation

The synthetic procedure pilot has twenty-four grounding examples and twelve two-member demographic pairs. Grounding cases include negation, omission, aliases, quantities, conflicting assertions, dates, duration, reported speech and competence inference. Claim origin distinguishes candidate source discrepancy from unsupported model assertions. The cases are authored inputs, not observed provider outputs. Annotators judge general semantic support beyond the implemented grammar, allowing coverage gaps to appear in the evaluation.

The earlier pilot pairs cover three junior technical roles and four declared signals: pronouns, age, marital status and disclosed disability. Within each pair, the job, technical evidence and answer are identical. These pilot inputs require faculty review and a college-specific redesign before a larger study; they do not represent a student population. Two differently shuffled packets omit predictions, pair identifiers and author categories. Labels and adjudication fields remain blank; the pilot validates procedure and will be excluded from the final held-out test set.

Two human reviewers independently label claims as source-supported, source-contradicted or undetermined, citing exact evidence spans and recording ambiguity. Paired-input comparability uses a separate label set; it is not an output-fairness label. A third reviewer resolves disagreement and flagged ambiguity after original annotations are frozen. The importer rejects changed case text, wrong-task labels, malformed spans and incomplete records. Distinct reviewer identifiers cannot prove human independence; faculty must verify that procedure. Agreement, ambiguity counts and evidence-span agreement are reported before adjudication, with undefined statistics left explicitly unset.

D. Metrics, Analysis and Reproducibility

Security evaluation counts unauthorized transitions, replay acceptance, cross-tenant leakage, tampered-score acceptance and audited decisions. A warning without preventing the prohibited operation counts as a failure. Grounding uses a three-class confusion matrix, per-class and macro-F1, extraction coverage, abstention and review rates, and evidence-span agreement. Candidate-origin and model-origin claims are reported separately. Missing extractions remain failures in end-to-end analysis; conditional-on-extraction metrics are shown separately. An empty extracted subset receives no successful accuracy value.

Bias analysis compares paired output scores only when the rubric is meaningful and the scores are available. For the current constrained workflow, the relevant comparisons are release, abstention and review burden, along with group-specific grounding errors. Missing or held scores are not replaced by zero. Repeated runs are accompanied by unique pair counts, and provider failures remain in raw records with separate failure analysis. Academic grading or ranking claims require a validated task and rubric; neither is evaluated here.

For a final powered study, sample size, primary outcomes and analysis rules must be fixed before collection. The protocol calls for uncertainty intervals, paired analysis and multiplicity correction where appropriate; the present descriptive utility does not implement population inference. Pilot cases used to estimate variance or refine instructions must not enter the final test set. A zero observed failure count must be accompanied by its sample size and uncertainty, not a claim of zero risk.

Each report records source/input hashes, case identifiers, model/configuration metadata, raw response references, decisions and error states. Raw artifacts must be reviewed without exposing credentials or applicant data. Tables for efficacy will be generated from frozen annotations and prediction exports after collection. No such tables are populated in this paper. At present, the completed evidence consists of implementation verification and an offline recording protocol, with no live model calls or independent efficacy labels.

VII. Discussion and Limitations

The strongest current result is an inspectable release boundary. A browser cannot authoritatively select a tenant, reviewer role or assessment score. A model cannot add a score field, cite an absent source or bypass a failed durable commit while remaining within the demonstrated workflow. Selected sensitive signals and source contradictions create an auditable review transition. This makes the interaction between access authority and output authority concrete, which is the principal architectural contribution.

The checks leave substantial semantic limitations, now visible in P2, P7 and P9. Quotation matching verifies a substring relationship, not entailment, external truth, salience or completeness. The controlled grammar misses general resume prose and does not model changes over time. A quoted sensitive disclosure may cause unnecessary review, whereas indirect discriminatory language can escape the trigger vocabulary. A reviewer can authorize an artifact without establishing its fairness. Consequently, neither test counts nor the number of rules supports a claim that bias or hallucination has been eliminated.

Operational generalization is also limited. The reference backend is single-instance, sessions are memory-resident, evidence is plaintext, and the audit chain is not externally anchored. The optional provider has not been exercised live, and timeout or model-version effects have not been measured in deployment. The current provider contract asks for quotations only; legacy practice/continue recommendations are withheld in storage and read paths because a keyword fixture cannot justify an assessment judgment. The synthetic pilot contains no real applicants and only selected language, roles and demographic signals. Any later use of candidate data requires institutional approval, appropriate participation and data minimization, with a process to contest outcomes. The current score must not be used for academic grading or autonomous placement decisions.

The architecture, code boundary and preliminary verification describe the present artifact. Independent annotation, a meaningful task rubric and recorded live provider outputs are required before making empirical efficacy claims. These are missing research evidence, not formatting details. Further claims should follow that evidence rather than be inferred from a working interface or a successful API integration.

VIII. Conclusion

The TrustInterview AI architecture couples resource access and feedback release through server-owned assessment state. It binds candidate evidence, validates constrained provider artifacts, supports reasoned review and preserves selected failure transitions transactionally. Current verification records 91 passing backend tests and six interface tests; negative-case testing also exposes the copied-token limitation. Nine authored output probes show enforced boundaries and semantic blind spots. A separate earlier artifact records twelve analysis-tool tests and 48 offline pilot records for recording and importer compatibility. These findings concern selected workflow behaviours; general semantic grounding, demographic fairness, student competence scoring and live-provider reliability remain unvalidated. Independent annotation and paired model experiments are required to test whether the architecture improves AI interview outcomes beyond enforcing its explicit boundaries.

Acknowledgment

We thank Prof. Apoorva Chate for guidance on this project.

References

[1] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," NIST Special Publication 800-207, Aug. 2020.

[2] R. Chandramouli and Z. Butcher, "A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments," NIST Special Publication 800-207A, Sep. 2023, doi: 10.6028/NIST.SP.800-207A.

[3] National Institute of Standards and Technology, "Implementing a Zero Trust Architecture: High-Level Document," NIST Special Publication 1800-35, Jun. 2025, doi: 10.6028/NIST.SP.1800-35.

[4] National Institute of Standards and Technology, "Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile," NIST AI 600-1, Jul. 2024, doi: 10.6028/NIST.AI.600-1.

[5] S. Min *et al.*, "FActScore: Fine-grained Atomic Evaluation of Factual Precision in Long Form Text Generation," in *Proc. EMNLP*, 2023, pp. 12076–12100, doi: 10.18653/v1/2023.emnlp-main.741.

[6] Y. Zha, Y. Yang, R. Li, and Z. Hu, "AlignScore: Evaluating Factual Consistency with A Unified Alignment Function," in *Proc. ACL*, 2023, pp. 11328–11348, doi: 10.18653/v1/2023.acl-long.634.

[7] S. Golchin, N. Garuda, C. Impey, and M. Wenger, "Grading Massive Open Online Courses Using Large Language Models," in *Proc. COLING*, 2025, pp. 3899–3912. [Online]. Available: https://aclanthology.org/2025.coling-main.263/

[8] A. Filighera, S. Parihar, T. Steuer, T. Meuser, and S. Ochs, "Your Answer is Incorrect... Would You Like to Know Why? Introducing a Bilingual Short Answer Feedback Dataset," in *Proc. ACL*, 2022, pp. 8577–8591, doi: 10.18653/v1/2022.acl-long.587.

[9] P. Manakul, A. Liusie, and M. Gales, "SelfCheckGPT: Zero-Resource Black-Box Hallucination Detection for Generative Large Language Models," in *Proc. 2023 Conf. Empirical Methods in Natural Language Processing*, 2023, pp. 9004–9017, doi: 10.18653/v1/2023.emnlp-main.557.

[10] A. Kwako and C. Ormerod, "Can Language Models Guess Your Identity? Analyzing Demographic Biases in AI Essay Scoring," in *Proc. 19th Workshop on Innovative Use of NLP for Building Educational Applications*, 2024, pp. 78–86. [Online]. Available: https://aclanthology.org/2024.bea-1.7/

[11] I. Weissburg, S. Anand, S. Levy, and H. Jeong, "LLMs are Biased Teachers: Evaluating LLM Bias in Personalized Education," in *Findings of NAACL*, 2025, pp. 5665–5713, doi: 10.18653/v1/2025.findings-naacl.314.

[12] H. An, C. Acquaye, C. Wang, Z. Li, and R. Rudinger, "Do Large Language Models Discriminate in Hiring Decisions on the Basis of Race, Ethnicity, and Gender?" in *Proc. 62nd Annual Meeting of the Association for Computational Linguistics, Short Papers*, 2024, pp. 386–397, doi: 10.18653/v1/2024.acl-short.37.

[13] H. Nghiem, J. Prindle, J. Zhao, and H. Daumé III, "You Gotta be a Doctor, Lin: An Investigation of Name-Based Bias of Large Language Models in Employment Recommendations," in *Proc. 2024 Conf. Empirical Methods in Natural Language Processing*, 2024, pp. 7268–7287, doi: 10.18653/v1/2024.emnlp-main.413.

[14] E. Fleisig *et al.*, "Linguistic Bias in ChatGPT: Language Models Reinforce Dialect Discrimination," in *Proc. EMNLP*, 2024, pp. 13541–13564, doi: 10.18653/v1/2024.emnlp-main.750.

[15] J. Dwivedi-Yu, "FairPair: A Robust Evaluation of Biases in Language Models through Paired Perturbations," in *Proc. Safety4ConvAI*, 2024, pp. 28–39. [Online]. Available: https://aclanthology.org/2024.safety4convai-1.4/

[16] P. Baxi, J. Xu, J. Y. Jiang, and S. Jasin, "Prompt Injection in Automated Résumé Screening with Large Language Models: Single and Multi-Injection Settings," in *Findings of the Association for Computational Linguistics: ACL 2026*, 2026, pp. 2942–2953, doi: 10.18653/v1/2026.findings-acl.142.

[17] OWASP Foundation, "OWASP Top 10 for LLM Applications 2025," OWASP GenAI Security Project, 2025. [Online]. Available: https://genai.owasp.org/llm-top-10/

[18] M. Jones and D. Hardt, "The OAuth 2.0 Authorization Framework: Bearer Token Usage," RFC 6750, Oct. 2012, doi: 10.17487/RFC6750.

[19] Google, "OpenID Connect," Google Identity documentation. [Online]. Available: https://developers.google.com/identity/openid-connect/openid-connect. Accessed: Oct. 11, 2026.

[20] Google, "Structured outputs," Google AI for Developers documentation. [Online]. Available: https://ai.google.dev/gemini-api/docs/generate-content/structured-output. Accessed: Oct. 11, 2026.